

# S3/Blob 저장소 보안 설정 가이드

## Object Storage Security Configuration Policy

버전: 1.0 | 시행일: 2025년 6월 1일 | 작성 부서: 인프라보안팀 / 클라우드운영팀

### 1. 목적

이 가이드는 사내에서 사용하는 \*\*클라우드 기반 객체 저장소(AWS S3, Azure Blob, GCS 등)\*\*에 대해 안전한 접근 제어와 데이터 보호를 위한 보안 설정 기준을 정의함으로써, 정보 유출 사고를 예방하고 법적 규정을 준수하는 것을 목적으로 합니다.

### 2. 적용 범위

- AWS S3, Azure Blob Storage, Google Cloud Storage 등
- 모든 버킷/컨테이너 및 내부에서 생성한 정적 파일, 로그, 백업 데이터
- 사용 주체: 개발자, 분석가, 인프라 운영자 등 저장소 접근 권한이 있는 모든 사용자

### 3. 저장소 생성 시 기본 설정

| 항목        | 설정값    | 설명                          |
|-----------|--------|-----------------------------|
| 공개 액세스 차단 | 기본 활성화 | Block all public access 필수  |
| 버전 관리     | 권장     | 삭제/오버라이드 방지용, 업무 로그 등에 적용   |
| 암호화 설정    | 기본 활성화 | SSE-S3, SSE-KMS 중 선택 가능     |
| 로깅 설정     | 권장     | 액세스 로그를 별도 버킷으로 저장 (보안 감사용) |

### 4. 접근 제어 정책

#### 4.1 버킷 정책(Bucket Policy)

- **Public: false** 설정이 기본
- **Principal: "\*" 이 포함된 정책은 전면 금지**
- IP 주소, VPC Endpoint, 사용자 Role 기반의 제한 적용

## 4.2 IAM 권한 설정

| 역할         | 권한 예시                                                    | 설명                    |
|------------|----------------------------------------------------------|-----------------------|
| 개발자        | <code>s3:GetObject,</code><br><code>s3:PutObject</code>  | 개별 폴더에 제한적으로 접근       |
| 데이터 분석가    | <code>s3:GetObject,</code><br><code>s3:ListBucket</code> | 읽기 전용 권장              |
| 운영자(Infra) | <code>FullAccess</code>                                  | 단, MFA 및 관리자승인 계정만 허용 |

## 5. 데이터 전송 보안

- **\*\*HTTPS 프로토콜(S3 HTTPS endpoint)\*\*을 통해 전송**
- 내부 서버 간 연동 시에도 프라이빗 엔드포인트 (**VPC Endpoint**) 사용 권장
- 외부로 연동되는 경우, 사전에 **API Gateway** 또는 프록시 구성 필요

---

## 6. 정적 파일 및 외부 공유

| 대상               | 공유 조건               | 주의사항                         |
|------------------|---------------------|------------------------------|
| 이미지, JS 등 정적 리소스 | 퍼블릭 URL 허용 가능       | 단, 민감한 메타데이터 포함 금지           |
| 데이터 파일 (CSV 등)   | 사내 접근자 한정           | IAM Role 또는 Presigned URL 사용 |
| 외부 파트너           | 임시 Presigned URL 발급 | 최대 유효시간 24시간 권장              |

## 7. 삭제 방지 및 백업

- 객체 잠금(**Object Lock**) 또는 **MFA Delete** 기능 사용 가능
- 정기 백업 파일은 별도 보안 버킷에 복제(**Mirror**) 보관
- 버킷 수명 주기(**Lifecycle Rule**)를 설정해 자동 보관/삭제 정책 적용

---

## 8. 보안 점검 및 감사

- 분기 1회 **S3** 퍼블릭 접근 여부 스캔 수행 (**AWS Config** 또는 **Security Hub** 연동)
- **CloudTrail**, **GCP Audit Logs** 활용하여 누가 언제 어떤 객체를 조회/변경했는지 로그 확보
- 권한 과다 계정 발견 시 즉시 조정 요청

---

## 9. 위반 시 조치

| 위반 유형          | 조치 내용                     |
|----------------|---------------------------|
| 퍼블릭 설정으로 외부 노출 | 경고 및 즉시 조정, 반복 시 정직 또는 징계 |
| 데이터 무단 다운로드    | 감사보고 후 해고 또는 민형사상 조치 가능   |
| 로그 미설정 또는 삭제   | 보안팀 감사 대상 및 내부 교육 재이수     |

## 10. 연계 지침 및 도구

- [IAM 권한 최소화 정책 가이드]
- [CloudTrail 로그 감사 매뉴얼]
- [S3 버킷 퍼블릭 접근 스캐너 배포 문서]
- [Azure Blob Shared Access Signature(SAS) 사용법]

---

## 11. 부칙

- 본 가이드는 2025년 6월 1일부터 시행되며, 연 1회 이상 보안팀 주관으로 리뷰 및 갱신합니다.